TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

OpsShield breach used to push malicious cPGuard updates that gave attackers root on about 2,950 servers

From **Cybersecurity Briefing** · 2026-11-04 to 2026-11-05 (last 24 hours; Indiana sections swept back to the 2026-10-31 cutoff) · Briefing generated 2026-11-05

REPORT ID	VERSION	HANDLING
CTI-20261105-06	1.0 · 2026-11-05 12:03 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
Global	2026-11-04	No update
CVES	**ANALYST**	
None	Nick Sturgeon	

SUPPLY CHAIN | HIGH | PATCH AVAILABLE | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

An unidentified attacker breached OpsShield, the Indian maker of the cPGuard Linux web server security suite, and used the product's own update channel to run a malicious script as root on customer servers. The vendor's updated disclosure says the attacker registered a customer account under a false identity on 1 November 2026, ordered a free trial, studied how the agent talks to the licensing system, sent crafted requests to billing portal callback pages at manage.opsshield.com, and gained command execution on the billing and licensing server at 22:58 UTC. Using stolen publishing keys, the attacker uploaded a fake update between 02:04 and 02:09 UTC on 2 November. Agents installed it between 02:08 and 03:20 UTC, a window of about 70 minutes [S3] [S1].

OpsShield estimates about 2,950 customer servers ran the script. It collected /etc/shadow and /etc/passwd, files under /root/.ssh, the MySQL root password in /root/.my.cnf where present, root shell history and, on a small number of servers, cloud storage keys in /root/.s3cfg. It also left a hidden setuid-root shell and a scheduled task. Separately, about 7,900 billing portal accounts were exposed (name, company, postal address, email, bcrypt password hash), and three OpsShield cloud servers were copied [S3] [S1]. The affected version range is 5.88.12 through 5.88.19 [S2] [S1].

Two points in the briefing excerpt need tightening. First, 5.88.25 is no longer sufficient as a target: the vendor's later disclosure names 5.88.26 as the clean release that removes the hidden shell, and a separate follow-up update removes the scheduled task, so defenders should move to the latest build and check for

the artifacts by hand [S3] [S5]. Second, updating does not undo the theft. The vendor's exposure rule is that any server with cPGuard online during the window should have its root-level secrets treated as compromised, and any server reachable by SSH keys from an exposed host is exposed until its keys are replaced [S3]. Neither a clean version log nor missing artifacts clears a server [S2].

Almost everything public traces back to the vendor's own two notices; we found no independent forensic write-up or malware analysis [S2] [S3] [S5]. Still unknown are the attacker's identity, the exact request that gave access to the billing server, the behavior of the scheduled task, how much data actually left customer servers, and whether the private half of OpsShield's support-access SSH key was exposed [S3] [S5]. The vendor also says it will keep updating its disclosure, so indicators and scope may change [S3]. Organizations should find out now whether they or their hosting providers run cPGuard, then update, rotate and hunt in that order, preserving evidence before deleting anything.

Key judgments

> **LIKELY · MODERATE CONFIDENCE**
> Attackers or buyers of the stolen data will use credentials and SSH keys taken from exposed servers for follow-on access to those servers or to systems that trust them within the next 30 days, because the script specifically targeted reusable root secrets and many hosts will not finish rotation quickly. [S3] [S5]

> **LIKELY · LOW CONFIDENCE**
> A meaningful share of affected server operators will update cPGuard but not complete full secret rotation, particularly small hosting businesses, because the rotation list touches root, all local users, databases, cloud keys and every system trusting the old SSH keys. [S3] [S6]

> **VERY LIKELY · HIGH CONFIDENCE**
> OpsShield or other researchers will publish further indicators or scope revisions in the next two weeks. The vendor's account has already changed on entry point, exfiltration destination, fix version and server count within about two days, and it says the investigation is continuing. [S2] [S3] [S5]

> **LIKELY · LOW CONFIDENCE**
> Billing portal customers will receive phishing that uses the stolen names, companies and addresses and refers to this incident, such as fake password reset or license reissue messages. The data suits this use and customers are expecting vendor contact about resets and license keys, although no such campaign has been reported yet. [S1] [S3]

> **UNLIKELY · LOW CONFIDENCE**
> A credible public attribution to a named actor will appear within 30 days. Current reporting names no group or nationality, and only one operator IP address has been published. [S3] [S5]

INDICATORS OF COMPROMISE

Reported indicators come from OpsShield's two notices (the first advisory published 2026-11-03, and the later Security Incident Disclosure, also dated 2026-11-03), which we opened directly; The Hacker News repeats the

same hashes and paths. They have not been independently validated, the vendor warns that their absence does not clear a server, and items marked as vendor internal server artifacts were not reported on customer servers.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`94[.]183[.]188[.]91`	Main attacker operator address per OpsShield. Search web, firewall and SSH logs. Dates of use were not published.	REPORTED		[S3] [S5]
user-agent	`cPGuard/5.88.11`	Fake user agent sometimes sent by the operator IP. Genuine agents may send a similar string, so treat it as a lead only when paired with other evidence.	REPORTED		[S3]
http-request	`*_rx.php`	URL path pattern for endpoints the attacker used to receive stolen data. The vendor does not name the host.	REPORTED		[S3]
http-request	`POST /*_rx.php`	Derived from the reported receiver endpoints: uploading collected files to a PHP receiver would normally use HTTP POST. The vendor does not state the method. Hunt for outbound requests from cPGuard servers around 2026-11-02 02:08 to 03:20 UTC.	DERIVED	2026-11-02	[S3]
filepath	`/i90248_probe.txt`	Probe file in a web root. The vendor does not say which servers held these files; check any web server that may have been targeted.	REPORTED		[S3]
filepath	`/i90573_probe.txt`	Probe file in a web root. Host not stated by the vendor.	REPORTED		[S3]
filepath	`/i90573_sh.php`	Listed with the vendor's probe files and web shells in a web root. Host not stated by the vendor.	REPORTED		[S3]
filepath	`/i90573_x.php`	Listed with the vendor's probe files and web shells in a web root. Host not stated by the vendor.	REPORTED		[S3]
filename	`i9xxxx*`	Vendor-described naming pattern for the attacker's web root files, where x is a digit. Useful as a low-fidelity hunt only.	REPORTED		[S3]
filepath	`/var/tmp/.cpg91511_sh`	Hidden setuid-root shell left on customer servers by the fake update. Preserve a copy, then delete it if a current cPGuard build has not removed it.	REPORTED	2026-11-02	[S2] [S3] [S5]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/var/tmp/.cpg91511`	Collection directory on customer servers, named in the first advisory. Not repeated in the removal list of the later disclosure, so check it separately.	REPORTED	2026-11-02	[S2] [S5]
filepath	`/var/tmp/.cpg91511/loot.tgz`	Staged archive of collected data on customer servers. If present, its contents show what was gathered on that host.	REPORTED	2026-11-02	[S2] [S5]
filepath	`/etc/cron.d/i93677`	Scheduled task left by the fake update. Its schedule and behavior are unpublished. Early fix builds did not remove it; a follow-up update does.	REPORTED	2026-11-02	[S3] [S5]
filepath	`/var/tmp/.i93677/`	Hidden directory of files left by the fake update on customer servers. Contents are not described.	REPORTED	2026-11-02	[S3] [S5]
filename	`cpguard-v58812-i91511*.sh`	Name pattern covering the four fake update script variants.	REPORTED	2026-11-02	[S3]
filename	`cpguard-v58812-i91511.sh`	Fake update script, base variant.	REPORTED	2026-11-02	[S2] [S3]
filename	`cpguard-v58812-i91511b.sh`	Fake update script, variant b.	REPORTED	2026-11-02	[S3] [S5]
filename	`cpguard-v58812-i91511c.sh`	Fake update script, variant c.	REPORTED	2026-11-02	[S3] [S5]
filename	`cpguard-v58812-i91511d.sh`	Fake update script, variant d.	REPORTED	2026-11-02	[S3] [S5]
sha256	`2c2acd988da531d133d0e17f245c49bf15781278f837543d18c95e8410eabd38`	SHA-256 of cpguard-v58812-i91511.sh.	REPORTED	2026-11-02	[S3] [S5]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
sha256	`ffd7a47f65fa1244429baa936ae94be54676b53d2f88bc39564f24e22011de8a`	SHA-256 of cpguard-v58812-i91511b.sh.	REPORTED	2026-11-02	[S3] [S5]
sha256	`d73919af84bf46de941db85e27fd1abc65701ef9ce6cf33bb27c5397f4a41c26`	SHA-256 of cpguard-v58812-i91511c.sh.	REPORTED	2026-11-02	[S3] [S5]
sha256	`6add0201e9a3d02de772d561d05e0da86eb1c538686753b7adcc3aedf7366f77`	SHA-256 of cpguard-v58812-i91511d.sh.	REPORTED	2026-11-02	[S3] [S5]
command	`grep 'Successfully updated' /opt/cpguard/logs/install_log`	Vendor-supplied check of update history. A match shows an affected update was installed, not that the script ran or data left. No match does not clear the server.	REPORTED		[S2] [S5]
other	`Successfully updated to 5\.88\.1[2-9]`	Derived regular expression for /opt/cpguard/logs/install_log, built from the vendor's affected range of 5.88.12 through 5.88.19 and its sample log lines. Timestamps in those samples have no stated time zone and run past the published window, so do not filter hits by time.	DERIVED	2026-11-02	[S2]
command	`find /var/tmp -xdev -type f -perm -4000`	Derived from the reported setuid-root shell in /var/tmp. Setuid files should not normally exist there, so this also catches a renamed copy. Run it with a known-good binary.	DERIVED		[S3]
filepath	`/usr/bin/defunct`	gsocket backdoor file. Found on an OpsShield internal server, not reported on customer servers.	REPORTED		[S3]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filename	`defunct.service`	Service unit name for the gsocket backdoor. Found on an OpsShield internal server, not reported on customer servers.	REPORTED		[S3]
filepath	`/lib/systemd/system/defunct.dat`	gsocket backdoor file. Found on an OpsShield internal server, not reported on customer servers.	REPORTED		[S3]
other	`[slub_flushwq]`	Process name displayed by the gsocket backdoor on an OpsShield internal server. The bracketed form imitates a kernel thread; a process with this name backed by an on-disk executable is suspicious.	REPORTED		[S3]
filepath	`/usr/sbin/pythno3`	Go implant copy (the name resembles a misspelled python3). Found on an OpsShield internal server, not reported on customer servers.	REPORTED		[S3]
filepath	`/usr/sbin/netstat.cfg`	Go implant copy. Found on an OpsShield internal server, not reported on customer servers.	REPORTED		[S3]
filepath	`/etc/profile.d/bash.cfg`	Go implant copy. Found on an OpsShield internal server, not reported on customer servers.	REPORTED		[S3]
filepath	`/usr/lib/system.mark`	Go implant copy. Found on an OpsShield internal server, not reported on customer servers.	REPORTED		[S3]
filepath	`/usr/lib/libgdi.so.0.8.2`	Go implant copy. Found on an OpsShield internal server, not reported on customer servers.	REPORTED		[S3]
filepath	`/boot/system.pub`	Go implant copy. Found on an OpsShield internal server, not reported on customer servers.	REPORTED		[S3]
other	`[rcu_gp]`	Process name displayed by the Go implant on an OpsShield internal server. The bracketed form imitates a kernel thread; a process with this name backed by an on-disk executable is suspicious.	REPORTED		[S3]
filepath	`/etc/profile.d/gateway.sh`	Script that hides the implant from ps, netstat, ls and find. Found on an OpsShield internal server. Inspect with a trusted boot environment or known-good static binary.	REPORTED		[S3]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/etc/shadow`	Legitimate file, not malicious. Collection target of the fake update; useful for auditd or EDR file access hunts on 2026-11-02.	REPORTED	2026-11-02	[S2] [S3]
filepath	`/etc/passwd`	Legitimate file, not malicious. Collection target of the fake update.	REPORTED	2026-11-02	[S2] [S3]
filepath	`/root/.ssh`	Legitimate directory, not malicious. Root SSH private keys, authorized_keys and known_hosts were targeted.	REPORTED	2026-11-02	[S3] [S5]
filepath	`/root/.my.cnf`	Legitimate file, not malicious. Holds the MySQL root password on some servers and was a collection target.	REPORTED	2026-11-02	[S3] [S5]
filepath	`/root/.s3cfg`	Legitimate file, not malicious. Cloud storage keys collected on a small number of servers.	REPORTED	2026-11-02	[S3] [S5]
filepath	`/root/.bash_history`	Derived. The vendor says root shell history was collected but gives no path; this is the default for root's bash shell. Other shells use other history files. Legitimate file, not malicious.	DERIVED	2026-11-02	[S3]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker began with an unusual step for a supply chain intrusion: becoming a customer. After probing manage.opsshield.com, the attacker registered under a false identity, ordered a free trial, installed it on their own server to learn the licensing traffic, then sent crafted requests to billing portal callback pages and gained command execution on the billing and licensing server. From there they harvested data and publishing keys, uploaded a fake update to the distribution infrastructure, and let customers' automatic update checks do the rest. The script ran as root, gathered password hashes, SSH material, database credentials, shell history and some cloud keys, staged them in a hidden /var/tmp directory, sent them out, and left a setuid-root shell plus a cron task for later access. The attacker also copied three of the vendor's cloud servers, and placed a gsocket backdoor, a Go implant and a hiding script on at least one vendor internal server [S2] [S3] [S5].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1595 Active Scanning	Probed the billing portal from 15:38 UTC on 2026-11-01, roughly seven hours before gaining command execution. [S3]	Review portal access logs from 2026-10-31 onward for sequential probing and requests to callback pages from unfamiliar sources.
Resource Development	T1585 Establish Accounts	Registered a customer account under a false identity at 16:34 UTC and ordered a free cPGuard trial, then installed it on their own server to study licensing traffic. [S1] [S3]	For software vendors: flag new trial accounts whose activity moves quickly to unusual license or callback requests.
Initial Access	T1190 Exploit Public-Facing Application	Crafted requests to billing portal callback pages led to command execution on the billing and licensing server at 22:58 UTC. The exact request is absent from the logs, and the vendor patched two possible entry points. [S1] [S3]	Alert on web server processes spawning shells, and on unexpected PHP files appearing in web roots.
Persistence	T1505.003 Server Software Component: Web Shell	The vendor lists probe files and web shells in a web root with i9xxxx names, including i90573_sh.php and i90573_x.php. It does not state which file does what or which host held them. [S3]	File integrity monitoring on web roots; search for the listed names and access to them.
Credential Access	T1552 Unsecured Credentials	Obtained the keys used to publish updates after gaining command execution. How and where they were stored has not been established. [S3] [S5]	For vendors: monitor use of publishing and cloud keys from unexpected hosts, and keep such keys off internet-facing servers.
Initial Access	T1195.002 Supply Chain Compromise: Compromise Software Supply Chain	Uploaded a fake cPGuard update with a stolen key between 02:04 and 02:09 UTC on 2026-11-02; agents retrieved it through the normal update channel between 02:08 and 03:20 UTC. [S2] [S3]	Review /opt/cpguard/logs/install_log for 5.88.12 through 5.88.19, then search for the script names and hashes.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	Shell scripts named cpguard-v58812-i91511*.sh ran as root on customer servers. [S2] [S3]	EDR or auditd: shell execution with these names, or child processes of the cPGuard updater reading credential files.

Tactic	Technique	Procedure observed	Detection opportunity
Credential Access	T1003.008 OS Credential Dumping: /etc/passwd and /etc/shadow	Script collected /etc/shadow and /etc/passwd. [S2] [S3]	auditd file watch on /etc/shadow for reads by anything other than expected system services.
Credential Access	T1552.004 Unsecured Credentials: Private Keys	Script collected root SSH private keys and other files under /root/.ssh. [S3] [S5]	Monitor reads of /root/.ssh; after rotation, alert on any login attempt with the retired keys.
Credential Access	T1552.001 Unsecured Credentials: Credentials In Files	Script collected the MySQL root password from /root/.my.cnf and, on a few servers, storage keys from /root/.s3cfg. [S3] [S5]	Review database and cloud storage audit logs from 2026-11-02 onward for new sources and unusual access.
Credential Access	T1552.003 Unsecured Credentials: Shell History	Script collected root shell history, which can contain typed secrets. [S2] [S3]	Inventory secrets in root history and audit where each was subsequently used.
Collection	T1074.001 Data Staged: Local Data Staging	Collected data was gathered under /var/tmp/.cpg91511 and packed as loot.tgz. [S2] [S5]	Watch for hidden directories and archive creation in /var/tmp by root.
Exfiltration	T1041 Exfiltration Over C2 Channel	Data was uploaded out of customer servers. The first advisory said it went to the vendor's licensing server under a compromised account; the later disclosure says a server the attacker controlled, and lists *_rx.php receiving endpoints. [S2] [S3] [S5]	Proxy, firewall and web logs: outbound requests from hosting servers to *_rx.php paths around the window.
Privilege Escalation	T1548.001 Abuse Elevation Control Mechanism: Setuid and Setgid	Left a hidden setuid-root shell at /var/tmp/.cpg91511_sh, which would let anyone with a local account regain root even after credentials change. [S2] [S3]	Regularly list setuid files and alert on any under /tmp or /var/tmp. Also review local and web tenant accounts on shared hosts.
Persistence	T1053.003 Scheduled Task/Job: Cron	Left /etc/cron.d/i93677 and supporting files in /var/tmp/.i93677/. Behavior not published. [S3] [S5]	File integrity monitoring on /etc/cron.d; cron jobs that execute from /var/tmp.

Tactic	Technique	Procedure observed	Detection opportunity
Defense Evasion	T1564.001 Hide Artifacts: Hidden Files and Directories	Used dot-prefixed names under /var/tmp for the shell and working directories. [S2] [S3]	Search for dot-prefixed executables and directories in temporary locations.
Impact	T1578.002 Modify Cloud Compute Infrastructure: Create Cloud Instance	Copied three OpsShield cloud servers at 02:13 UTC; the vendor later removed cloned servers and snapshots. Filed under Defense Evasion by ATT&CK; here the practical effect is data access, and the purpose is our inference. [S1] [S3]	Cloud audit log alerts for new snapshots, instance copies and new SSH keys.
Command and Control	T1219 Remote Access Tools	gsocket backdoor at /usr/bin/defunct with defunct.service, seen on an OpsShield internal server and not reported on customer servers. [S3]	Search for the listed files from a trusted environment; review outbound connections that do not match expected services.
Defense Evasion	T1036.005 Masquerading: Match Legitimate Resource Name or Location	Backdoor and Go implant appeared as [slub_flushwq] and [rcu_gp], names that resemble kernel threads, on an OpsShield internal server. pythno3 resembles python3. [S3]	Bracketed process names that have an on-disk executable or a parent other than kthreadd.
Defense Evasion	T1014 Rootkit	/etc/profile.d/gateway.sh hid the implant from ps, netstat, ls and find on an OpsShield internal server. The mechanism is not published, and the mapping to this technique is our judgment. [S3]	Compare results from a trusted boot environment or known-good static binaries with those from the live system.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

cPGuard fake update artifacts created on Linux hosts `SIGMA`

```
title: cPGuard Fake Update Artifacts
status: experimental
description: File events matching artifacts published by OpsShield for the November 2026 cPGuard
compromise
logsource:
  product: linux
  category: file_event
detection:
  selection_paths:
    TargetFilename|startswith:
      - '/var/tmp/.cpg91511'
      - '/var/tmp/.i93677'
      - '/etc/cron.d/i93677'
  selection_scripts:
    TargetFilename|contains: 'cpguard-v58812-i91511'
  condition: selection_paths or selection_scripts
falsepositives:
  - Incident response tooling restoring or copying evidence
level: critical
```

Covers customer-server artifacts only. Absence of hits does not clear a host because artifacts may have been removed by later updates.

Operator IP, fake user agent, receiver endpoints and web root files in web logs `SPLUNK SPL`

```
index=* earliest="10/31/2026:00:00:00" (src_ip="94.183.188.91" OR dest_ip="94.183.188.91" OR
clientip="94.183.188.91" OR http_user_agent="cPGuard/5.88.11*" OR uri_path="*_rx.php" OR uri_path IN
("/i90248_probe.txt", "/i90573_probe.txt", "/i90573_sh.php", "/i90573_x.php"))
| stats count min(_time) as first_seen max(_time) as last_seen values(uri_path) as uri_path
values(http_user_agent) as user_agent by host, src_ip, dest_ip
| convert ctime(first_seen) ctime(last_seen)
```

Adjust index and field names to your data. The user agent clause may match genuine cPGuard 5.88.11 agents; triage it alongside other evidence.

Network activity with the operator IP and _rx.php uploads `SURICATA`

```
alert ip 94.183.188.91 any <> $HOME_NET any (msg:"cPGuard incident - traffic with reported operator
IP"; classtype:trojan-activity; sid:9200101; rev:1;)
alert http $HOME_NET any -> $EXTERNAL_NET any (msg:"cPGuard incident - outbound POST to _rx.php path";
flow:established,to_server; http.method; content:"POST"; http.uri; content:"_rx.php"; nocase;
classtype:trojan-activity; sid:9200102; rev:1;)
```

The second rule depends on cleartext HTTP and will miss TLS without decryption. Change the SIDs to suit your local range.

Execution of reported scripts, hashes, implants or masqueraded kernel names on Linux `KQL`

```
DeviceProcessEvents
| where Timestamp > datetime(2026-11-01)
| where SHA256 in ("2c2acd988da531d133d0e17f245c49bf15781278f837543d18c95e8410eabd38",
"ffd7a47f65fa1244429baa936ae94be54676b53d2f88bc39564f24e22011de8a",
"d73919af84bf46de941db85e27fd1abc65701ef9ce6cf33bb27c5397f4a41c26",
"6add0201e9a3d02de772d561d05e0da86eb1c538686753b7adcc3aedf7366f77")
    or ProcessCommandLine has_any ("cpguard-v58812-i91511", "/var/tmp/.cpg91511", "/var/tmp/.i93677",
"/usr/sbin/pythno3", "/usr/bin/defunct", "[slub_flushwq]", "[rcu_gp]")
    or FolderPath startswith "/var/tmp/."
| project Timestamp, DeviceName, AccountName, FolderPath, FileName, ProcessCommandLine,
InitiatingProcessFileName, InitiatingProcessCommandLine, SHA256
| order by Timestamp asc
```

Assumes Microsoft Defender for Endpoint on Linux. Agents running at the time of compromise are required for historical hits. The FolderPath clause is broad and may need tuning.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
OpsShield cPGuard agent on Linux servers (used with cPanel, DirectAdmin and Plesk)	5.88.12 through 5.88.19 per the install log, plus any server with cPGuard online from 02:08 to 03:20 UTC on 2026-11-02	Latest build: 5.88.25 was named first, 5.88.26 is the clean release in the later disclosure, and a follow-up update removes the scheduled task (version number not stated)	None assigned	N/A	N/A	No	N/A
OpsShield billing portal (manage.opsshield.com)	About 7,900 accounts: name, company, postal address, email, bcrypt password hash	Vendor patched two possible entry points; users must reset their password and enable two-factor login	None assigned	N/A	N/A	No	N/A

Immediate (0–24 hours)

- Identify every server running cPGuard, including managed VPS and dedicated servers from hosting providers, and ask each hosting provider directly whether cPGuard runs on your systems. `IT OPS` [S6] [S9]

- Before cleaning, preserve evidence on likely affected hosts: install_log, the listed /var/tmp and cron artifacts, web and auth logs, and a disk snapshot where possible. `SOC` [S2] [S3]
- Run cpgcli update --start on each server, confirm with cpgcli --version, and make sure you have the latest build rather than stopping at 5.88.25. Contact vendor support if the update fails. `IT OPS` [S2] [S3] [S5]
- Confirm that /etc/cron.d/i93677, /var/tmp/.i93677/ and /var/tmp/.cpg91511_sh are gone, and also check /var/tmp/.cpg91511/. Delete anything left after preserving a copy. `IT OPS` [S2] [S3] [S5]
- Change the root password and all local user passwords on exposed hosts, using a trusted recovery environment where possible, and change any of those passwords reused elsewhere. `IT OPS` [S2] [S3]
- Generate new root SSH keys, remove old public keys from every system that trusted them, review authorized_keys for unknown entries, and treat systems reachable with the old keys as exposed until done. `IT OPS` [S2] [S3]
- Change the MySQL root password and database passwords in /root/.my.cnf, and rotate S3 keys, DigitalOcean tokens and any secrets found in root shell history or /root/.s3cfg. `IT OPS` [S2] [S3] [S5]
- Reset OpsShield billing portal passwords and enable two-factor login, even for servers that were offline during the window. Change that password anywhere it was reused. `IT OPS` [S1] [S3]
- Hunt for the reported IP, script hashes, file paths and *_rx.php requests across logs from 2026-10-31 onward, using the queries in this report. `SOC` [S2] [S3]

Short term (1–7 days)

- Rebuild from a backup taken before 1 November any server showing manual attacker login or other signs of compromise. The vendor does not recommend routine rebuilds, but set a lower threshold for high-value or regulated systems. `IT OPS` [S2] [S3]
- Review auth logs, database logs and cloud storage audit logs since 2026-11-02 for use of the exposed secrets, including from sources other than the published IP. `SOC` [S3]
- Inspect suspect hosts from a trusted boot environment or known-good static binaries for the vendor-internal implant files, since the hiding script defeats ps, netstat, ls and find. This extends the vendor's advice as a precaution; the implants were not reported on customer servers. `SOC` [S3]
- Check root authorized_keys for OpsShield support-access keys and confirm the vendor's precautionary update removed them, because it is unknown whether the matching private key was exposed. `IT OPS` [S2] [S5]
- Use the vendor lookup reported by The Hacker News, or open a support ticket, to ask about your servers, but do not treat a missing record as clearance. Follow any instructions on the license key reissue through authenticated vendor channels. `IT OPS` [S3] [S5]
- Warn staff with billing portal access about phishing that refers to this incident, password resets or license reissues. `SOC` [S1] [S3]
- Have legal and compliance staff assess notification duties where exposed servers host customer, patient or student data. `LEADERSHIP` [S3]

Long term

- Inventory all vendor agents with root-level or auto-update privileges and record each vendor's update signing, key handling and incident notification commitments. `LEADERSHIP` [S6]
- Keep secrets out of shell history, and limit credential files on servers. Replace long-lived root SSH keys and static keys with short-lived or restricted credentials where possible. `IT OPS` [S6]
- Stop sharing SSH keys across tenants or environments so one stolen key cannot open many systems. `IT OPS` [S3]
- Add a supply chain compromise of a trusted security tool to tabletop exercises and include monitoring after updates. `LEADERSHIP` [S6]
- Send hosting server telemetry to a central location that a root-level intruder cannot easily alter, including auditd, file integrity and egress logs. `SOC` [S3]

Workarounds & compensating controls

- Restrict outbound traffic from hosting servers to required destinations, and restrict management ports to known addresses. Egress limits would make script uploads and callback traffic harder. `IT OPS` [S8]
- Block the reported operator IP at the perimeter as a low-cost measure, but do not rely on it because a single address is easily changed. `SOC` [S3]
- If rotation cannot be finished right away, mount /var/tmp with nosuid and noexec where applications tolerate it. This limits the setuid shell technique but does not undo the theft. `IT OPS` [S3]
- Consider holding cPGuard auto-updates on critical hosts only after weighing the risk, since you would also delay the cleanup updates. Apply the current updates first. `LEADERSHIP` [S3]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] SecurityWeek: Malicious cPGuard Updates Served in OpsShield Supply Chain Attack
Published 2026-11-04 · `B2` Usually reliable, probably true
Briefing's source link. Relies on the vendor's notices and lists no indicators. Still gives 5.88.25 as the fix.

[S2] OpsShield: cPGuard Update Channel Compromise (advisory)
Published 2026-11-03 · `A3` Completely reliable, possibly true
Primary source, opened directly. Last updated 3:19 AM IST on 3 November. Partly superseded by S3 on entry point, exfiltration destination and scope.

[S3] OpsShield: Security Incident Disclosure: manage.opsshield.com
Published 2026-11-03 · **A2** Completely reliable, probably true
Primary source, opened directly, with the fullest indicator table. The victim reporting on itself; the vendor says the post will be updated. Not independently verified.

[S4] BleepingComputer: Hackers hijack cPGuard autoupdate to deploy backdoor, steal data
Published 2026-11-03 · **B2** Usually reliable, probably true
Source of the 2,946 figure from a vendor spokesperson. Its 32-files wording differs from the vendor's.

[S5] The Hacker News: cPGuard Update Channel Hijacked to Backdoor Linux Servers and Collect Password Hashes
Published 2026-11-03 · **B2** Usually reliable, probably true
Updated 2026-11-04 with a correction on the scheduled task. Compares the two vendor notices and covers the support-access keys and lookup tool. Adds no independent forensics.

[S6] Network World: Attackers turned OpsShield's trusted update channel into a supply-chain attack
Published 2026-11-04 · **B2** Usually reliable, probably true
Restates the vendor's account and adds outside analyst commentary on privileged agents and update trust.

[S7] Aviatrix: cPGuard Autoupdate Hijack 2026: Supply-Chain Backdoor & Data Theft on 2,946 Servers
Published 2026-11-04 · **C4** Fairly reliable, doubtful
Vendor marketing based on early reporting. Its 12-hour distribution window and 32 files per host conflict with the primary sources. Used only to document the discrepancy.

[S8] DEV Community (user Anoymask): cPGuard Supply Chain Compromise: Legitimate Auto-Update Distributes Backdoor and Root Credential Harvesting Script
Published 2026-11-04 · **F3** Reliability cannot be judged, possibly true
Pseudonymous community post summarizing vendor notices and press. Used only for its egress and management port suggestion.

[S9] Namecheap: What Is cPGuard?
Published · **B2** Usually reliable, probably true
Product background and confirmation that the product is sold with VPS and dedicated servers. Does not mention the incident. Publication date not shown.

[S10] Shattered: cPGuard Supply Chain Attack: 2,950 Servers Hit [2026]
Published · **F3** Reliability cannot be judged, possibly true
Secondary commentary. Used only to locate a vendor reply on the Enhance community forum, which would not load for us.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-11-01	15:38 UTC: attacker begins probing manage.opsshield.com.	[S3]
2026-11-01	16:34 UTC: attacker registers a false-identity customer account and orders a free cPGuard trial.	[S3]
2026-11-01	21:17 UTC: attacker installs the trial on their own server. cPGuard flags and bans the attacker twice between 21:40 and 21:51 UTC.	[S3]
2026-11-01	22:50 UTC: crafted requests sent to billing portal callback pages. 22:58 UTC: command execution on the billing and licensing server.	[S3]
2026-11-02	02:04 to 02:09 UTC: fake update uploaded with a stolen key. The first advisory gives 02:06 UTC for access to the update CDN.	[S2] [S3]
2026-11-02	02:08 to 03:20 UTC: agents install the fake update, which runs as root and copies sensitive files out.	[S3]
2026-11-02	02:13 UTC: attacker copies three OpsShield cloud servers.	[S3]
2026-11-02	Stolen update key revoked and clean v5.88.26 published. The vendor says it detected the compromise within 12 hours of the affected updates.	[S2] [S3]
2026-11-03	Vendor advisory published with 5.88.25 as the fix and a preliminary estimate of 32 retrieved files; last updated 3:19 AM IST (21:49 UTC on 2 November). Later the same day, the fuller disclosure traces the entry point to the billing portal.	[S2] [S3]
2026-11-03	BleepingComputer reports a spokesperson's count of 2,946 servers.	[S4]
2026-11-04	SecurityWeek and Network World report the updated account. The Hacker News corrects its article to say the scheduled task needs a separate follow-up update.	[S1] [S5] [S6]

Relevance to Indianapolis, Indiana & managed clients

We found no public list of affected organizations and no report naming an Indiana victim, so direct local impact is unknown. The realistic exposure is through web hosting. Indiana municipalities, schools, clinics, manufacturers and small businesses often run public websites, client portals or email on cPanel, DirectAdmin or Plesk servers, either on their own VPS or through a provider, and cPGuard may be present without the customer knowing because hosts bundle it (Namecheap, for example, offers it with VPS and dedicated servers [S9]). On shared hosting a root compromise can affect every tenant on the server, including database contents behind a site. Healthcare and government organizations should treat confirmed exposure as a possible data incident and bring

in counsel early, since database passwords were within reach. Managed IT service clients should expect three questions from their provider: whether cPGuard runs on any managed or client-procured server, whether a shared root or administrative SSH key on an exposed host could reach other clients, and whether any staff member holds an OpsShield billing account. Providers should check their inventory and RMM data today, contact third-party hosts in writing, and record the answers for each client.

Intelligence gaps

- Actor identity, motive and origin are unknown. Only one operator IP is public, and we did not attribute it.
- The exact request and flaw that gave command execution are not in the logs. Two possible entry points were patched, and the billing software or vendor components involved are unnamed.
- How the publishing key was obtained and stored, and whether signing checks exist or failed, are not explained. The vendor says only that it is hardening its update and signing process.
- The actual volume of stolen data is unpublished. The 32-file figure was a preliminary count of files retrieved from the licensing server and is not a limit on exposure.
- The attacker-controlled exfiltration server and full *_rx.php URLs are not named. No hashes were published for the setuid shell, cron file or implants.
- Behavior of /etc/cron.d/i93677 and the contents of /var/tmp/.i93677/ are not described, so what happens between now and the task's removal is unclear.
- The server holding the web root probe files and web shells is not stated.
- Whether the private half of the OpsShield support-access key was exposed has not been stated.
- The follow-up update's version number is unavailable. We could not find a current change log: the change log page we tried returned 404.
- We could not open the vendor reply on the Enhance community forum because the page would not load. It may hold further detail.
- What data sits in the copied cloud servers, and whether downstream actions have started, are unknown. Watch for an updated vendor disclosure, independent malware analysis, reports of follow-on abuse, and statements from large hosting providers.

Other notes

- Entry point changed between vendor notices. The first advisory and early press describe compromised credentials used against the update CDN; the later disclosure traces this back to code execution on the billing and licensing server, from which publishing keys were stolen. Use the later account [S2] [S3] [S1].
- Exfiltration destination changed. The first advisory says the data went to the vendor's licensing server under a compromised account; the later disclosure says a server the attacker controlled. Both may be partly true, but the vendor has not reconciled them [S2] [S3] [S5].
- Server count differs slightly: about 2,950 in the vendor disclosure and 2,946 from a spokesperson. These are close enough to treat as the same estimate, and neither has been independently verified [S3] [S4].
- The 32-file figure is reported inconsistently. The vendor describes 32 collected files, each matching a customer server. BleepingComputer's wording reads as 32 per customer and Aviatrix states 32 per host. The vendor's wording should be preferred, and the figure should not be used to size the incident [S2] [S4] [S7].
- Time window caution. The vendor's sample log lines show updates to 5.88.15 through 5.88.19 from 04:46 to 12:46, which is after the 03:20 UTC end of the published window if those times are UTC. The vendor does not

state a time zone and says timestamps may differ. Until this is explained, we recommend treating any host that logged 5.88.12 through 5.88.19 as in scope regardless of time [S2] [S3].

- Lookup tool. The Hacker News describes a lookup on the vendor's disclosure page that checks IPs or hostnames against incident records, but the page text we retrieved did not show it, possibly because it is an interactive element. A missing record does not clear a server [S5] [S3].
- Item dates. The briefing's original date of 2026-11-04 reflects the SecurityWeek article; the vendor's notices and first press reports date from 2026-11-03.
- The vendor stated that the billing portal data it lists does not include payment card data only by omission: the disclosure simply does not mention card data, so its absence should not be taken as confirmation [S3].
- OpsShield's closing remark that attackers now use AI tools to move faster is a general comment and is not evidence that this attacker did so [S3].

CTI-20261105-06 v1.0 · Generated 2026-11-05 12:03 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.